

UmbraMarket — VAPT Final Report Template

Template studenti. Tutti i dati del laboratorio sono fittizi.

1. Document Control

Field	Value
Customer	UmbraMarket S.r.l.
Engagement	
Assessment type	
Assessment dates	
Report date	
Report version	
Classification	Training / Confidential
Prepared by	
Reviewed by	

Version history

Version	Date	Author	Change
0.1			Draft
1.0			Final

2. Executive Summary

Massimo 200–250 parole.

Rispondere senza gergo inutile:

- perché è stato eseguito l'assessment;
- cosa è stato valutato;
- quali rischi principali sono stati dimostrati;
- cosa **non** è stato dimostrato;
- quali azioni sono prioritarie.

Non inserire payload o dettagli operativi non necessari.

3. Engagement Objectives

Business questions

-
-

Security objectives

-
-

4. Scope

In scope

Asset / process	Type	Notes
-----------------	------	-------

Out of scope

Asset / process	Reason
-----------------	--------

Test accounts

Account	Role	Purpose
---------	------	---------

Non inserire password reali nel report finale.

5. Rules of Engagement

Riassumere:

- attività consentite;
- attività vietate;
- stop conditions;
- finestre temporali;
- eventuali vincoli operativi.

6. Methodology

Descrivere il processo realmente seguito.

Esempio di struttura:

```
customer discovery
→ scope validation
→ attack surface mapping
→ reconnaissance / enumeration
→ vulnerability assessment
→ manual validation
→ controlled proof
→ impact analysis
→ reporting
```

Spiegare anche:

- come sono stati trattati gli alert automatici;
- come sono state validate le ipotesi;
- quando è stata applicata una stop condition;
- come sono state raccolte le evidenze.

7. Limitations and Assumptions

Documentare ciò che limita le conclusioni.

Esempi:

- durata dell'assessment;
- asset non testati;
- social engineering non eseguito;
- physical security non eseguita;
- bulk enumeration non eseguita;
- denial of service escluso;
- uso di dati fittizi;
- vulnerabilità che richiederebbero finestre diverse;
- controlli dichiarati ma non verificati.

Una limitazione non è un difetto del report: impedisce overclaim.

8. Attack Surface Summary

Riassumere le superfici rilevanti:

```
TECHNICAL
HUMAN
PROCESS
```

IDENTITY
PHYSICAL
THIRD-PARTY
INFORMATION
TIME

Indicare quali sono state:

OBSERVED
VALIDATED
NOT TESTED
OUT OF SCOPE
DEPRIORITIZED

9. Findings Summary

ID	Finding	Asset / Process	Severity	Status
F-01				CONFIRMED
F-02				
O-01				OBSERVATION

Separare vulnerabilità confermate da osservazioni/hardening.

10. Detailed Findings

F-01 — [Title]

Severity

Informational / Low / Medium / High / Critical

Se usate CVSS, riportare anche versione, vettore e motivazione.

Affected asset

Category

Esempi:

Authorization
Authentication
Configuration
Information Disclosure
Process
Identity

Status

CONFIRMED

Summary

Spiegare il problema in poche righe.

Business rule / expected control

Quale comportamento di sicurezza era atteso?

Preconditions

Cosa deve essere vero prima che il test sia possibile?

Validation method

Descrivere il test eseguito senza aggiungere attività non realmente svolte.

Steps to reproduce

- 1.
- 2.
- 3.

I passaggi devono essere sufficienti a un team autorizzato per rifare il test.

Expected result

Observed result

Evidence

Evidence ID	Description
E-01	
E-02	

Non affidarsi soltanto a screenshot: conservare anche request/response o output testuale quando possibile.

Demonstrated impact

Descrivere solamente l'impatto dimostrato.

Not demonstrated / boundaries

Dichiarare esplicitamente cosa non è stato verificato.

Root cause

Spiegare la causa, non soltanto il sintomo.

Remediation

Distinguere quando utile:

Immediate

Structural

Retest procedure

Descrivere come verificare la correzione.

References

Aggiungere standard o riferimenti solo se utili.

11. Observations and Non-Findings

Questa sezione può includere:

- hardening;
- ipotesi non confermate;
- false positive significativi;
- controlli che hanno funzionato;
- superfici non testate ma rilevanti.

Non trasformare un risultato negativo in una vulnerabilità.

12. Remediation Roadmap

Priority	Action	Finding / Area	Owner suggestion	Retest
P1				
P2				
P3				

La priorità deve considerare anche il contesto del cliente, non solo la severity tecnica.

13. Retest Plan

Definire:

- cosa verrà ritestato;
- evidenza attesa;
- criteri PASS/FAIL;
- eventuali dipendenze.

Esempio:

PASS:

un customer autenticato richiede un ordine di un altro customer e riceve 403/404 senza dati dell'oggetto.

FAIL:

la risposta continua a contenere dati dell'ordine non appartenente all'utente autenticato.

14. Evidence Register

ID	Timestamp	Test	Asset	Evidence file	Supports
E-01					
E-02					

Le evidenze devono essere:

- minimali;
- pertinenti;
- riproducibili;
- prive di segreti non necessari;
- collegate a una conclusione precisa.

15. Conclusion

Chiudere con:

- risultato complessivo dell'engagement;
- principali rischi dimostrati;

- priorità immediate;
- limiti principali;
- raccomandazione di retest.

Non introdurre nuove evidenze nella conclusione.